

A Hardened Cryptographic Theory for PUF-Based Four-Phase UAV-Swarm Authentication

Corrected Specification, Formal Assumptions, and Security Proofs

Abstract

We present a corrected cryptographic foundation for a four-phase Physical Unclonable Function (PUF)-based authentication protocol for Unmanned Aerial Vehicle (UAV) swarms. The redesign eliminates every theoretical flaw of the previous specification: unkeyed “authenticators”, a chosen-challenge PUF read-out oracle, a plaintext swarm-wide credential, the absence of forward secrecy, an unsound helper-data independence assumption, and a saturating single-use challenge budget. The corrected trust model derives a *stable* per-device master key from the PUF through a fuzzy extractor with a mathematically correct min-entropy accounting; the device stores no secret. All authenticators become keyed message-authentication codes; the raw PUF response never leaves the device; peer authentication is rooted in per-pair credentials delivered under authenticated encryption; and an authenticated ephemeral Diffie–Hellman exchange provides mandatory forward secrecy. We give six theorems—mutual authentication (both directions), peer mutual authentication, replay/MITM resistance, physical-capture resistance, session-key secrecy, and perfect forward secrecy—each with a game-based reduction to standard assumptions, and we accompany them with a symbolic (Tamarin/applied- π) model and its verification lemmas.

Contents

1	Introduction and Scope	2
2	Preliminaries and Cryptographic Primitives	2
2.1	Hash function and dual-mode instantiation	2
2.2	Keyed primitives	2
2.3	Ephemeral key exchange	3
2.4	PUF and fuzzy extractor (corrected)	3
3	System and Threat Model	4
4	Design Rationale: From Defects to Guarantees	5
5	The Hardened Four-Phase Protocol	5
5.1	Phase 1 — Secure Enrolment	5
5.2	Phase 2 — UAV $\leftrightarrow$ GS Mutual Authentication	6
5.3	Phase 3 — UAV $\leftrightarrow$ UAV Peer Authentication	6
5.4	Phase 4 — Session Keys and Mandatory Forward Secrecy	7
6	Security Theorems and Game-Based Proofs	7

Table 1: Theory defects of the previous specification (audit Part A) and where each is resolved.

Ref	Defect	Root cause	Resolved in
A.1	GS→UAV auth absent	authenticators are unkeyed hashes of public data	Section 5.2, Thm. 3
A.2	PUF read-out oracle	response masked by $h(N_2)$ with N_2 public	Section 5.2, Cor. 4
A.3	Swarm-wide plaintext Cred	one shared secret, no confidentiality/authenticity	Section 5.3, Thm. 5
A.4	No forward secrecy	keys are deterministic in long-term secrets	Section 5.4, Thm. 9
A.5	Unsound helper-data claim	“independence” instead of $\tilde{H}_\infty$ bound	Section 2, Lem. 2
A.6	CRP exhaustion / DoS	single-use challenges, unauthenticated request	Sections 5.1 and 5.2
A.7	Phase-3 confusion	no domain separation / freshness	Section 5.3, Thm. 6

7	Symbolic Model and Mechanised Verification	9
8	Comparison with the Previous Specification	10
9	Conclusion	10

1 Introduction and Scope

This document specifies *only* the cryptographic theory of the protocol. It supersedes the theory analysed in the accompanying audit (REPORT.md, Part A). No implementation, simulation, or empirical claim is made here; the primitives are treated abstractly and instantiated with standard concrete choices only where it clarifies the design.

The audit identified seven theory-level defects, summarised in Table 1. The rest of this paper is organised so that each defect is mapped to a concrete design decision (Section 4) and then provably neutralised by a phase specification (Section 5) and a theorem (Sections 6 and 7).

2 Preliminaries and Cryptographic Primitives

Let λ be the security parameter. A function is *negligible*, written $\text{negl}(\lambda)$, if it vanishes faster than any inverse polynomial. $x \xleftarrow{\$} S$ denotes uniform sampling; $\parallel$ is concatenation; $\oplus$ is bitwise XOR. All concatenations are unambiguously parseable (length-prefixed).

2.1 Hash function and dual-mode instantiation

$h : \{0, 1\}^* \rightarrow \{0, 1\}^{160}$ is a cryptographic hash, instantiated in either of two interoperable modes—**SHA3-256 truncated to 160 bits** or **SPONGENT-160**—exactly as in the reference design, so the dual-mode performance characterisation is preserved. In the computational proofs h is modelled as a random oracle; where a keyed primitive is required we do *not* use h bare (this is the central correction of A.1) but the dedicated keyed constructions below.

2.2 Keyed primitives

Definition 1 (MAC, EUF-CMA). $\text{MAC} : \{0, 1\}^\lambda \times \{0, 1\}^* \rightarrow \{0, 1\}^\lambda$ is *existentially unforgeable under chosen-message attack* if for every PPT $\mathcal{A}$ the advantage

$$\text{Adv}_{\text{MAC}}^{\text{euf}}(\mathcal{A}) = \Pr[\mathcal{A} \text{ outputs a fresh valid } (m, \text{MAC}_K(m))] \leq \text{negl}(\lambda),$$

for $K \xleftarrow{\$} \{0, 1\}^\lambda$. We instantiate MAC as HMAC- h (equivalently a sponge/keyed duplex MAC over the chosen h).

Definition 2 (Nonce-based AEAD). $\text{AE} = (\text{Enc}, \text{Dec})$ with $\text{Enc}_K(\eta; ad; m) \rightarrow c$ and $\text{Dec}_K(\eta; ad; c) \rightarrow m/\perp$ is *IND-CCA* secure (ciphertext indistinguishability) and provides *INT-CTXT* (ciphertext integrity), with advantages $\text{Adv}_{\text{AE}}^{\text{ind}}, \text{Adv}_{\text{AE}}^{\text{int}} \leq \text{negl}(\lambda)$ for distinct nonces η . We instantiate AE with a lightweight nonce-based AEAD (Ascon-AEAD class), aligned with the protocol’s lightweight target.

Definition 3 (KDF). KDF is HKDF (Extract-then-Expand). Every derivation carries a unique *domain-separation label*; $\text{KDF}(k; \ell)$ denotes expansion of key material k under a label

$$\ell \in \{\text{“p2-auth”, “p2-sess”, “pair-cred”, “peer-auth”, “peer-sess”, “pfs”}\}.$$

We model $\text{KDF}(\cdot; \ell)$ as an independent PRF for each ℓ ; distinct labels give independent keys (domain separation), correcting A.7.

2.3 Ephemeral key exchange

$\mathbb{G}$ is the group underlying **X25519** with generator g . Security of forward secrecy is reduced to the *gap computational Diffie–Hellman* (gap-CDH) assumption, equivalently the PRF-ODH assumption for KDF over $\mathbb{G}$.

2.4 PUF and fuzzy extractor (corrected)

Each device i embeds a strong PUF $\text{PUF}_i : \{0, 1\}^c \rightarrow \{0, 1\}^n$. Repeated evaluations of the same challenge differ in at most t bits with overwhelming probability (bounded bit-error rate). We make the standard, *correctly stated* assumptions.

Assumption 1 (PUF unpredictability). For a challenge C not previously queried, and given any polynomial set of challenge–response pairs of PUF_i , the response $\text{PUF}_i(C)$ is computationally indistinguishable from uniform to a PPT adversary that does not physically possess device i .

Assumption 2 (Tamper-evidence). Invasive probing of device i destroys PUF_i ; its challenge–response behaviour cannot be extracted from captured silicon or transferred to another device.

We use a *fuzzy extractor* $\text{FE} = (\text{Gen}, \text{Rep})$ built from a code-offset secure sketch over a binary linear code $\mathbf{C}$ with parameters (n, k, t) (instantiated as the *correctly parameterised* BCH(255, 131, 18), so $n - k = 124$ parity bits and error-correction radius $t = 18$), composed with a strong extractor realised by KDF:

$$\begin{aligned} \text{Gen}(R) : \quad & r \xleftarrow{\$} \{0, 1\}^k, \quad c = \mathbf{C}.\text{Encode}(r), \quad s = R \oplus c, \quad \text{seed} \xleftarrow{\$} \{0, 1\}^\lambda, \\ & \text{mk} = \text{KDF}(\text{Ext}_{\text{seed}}(R); \text{“root”}), \quad P = (s, \text{seed}), \quad \text{return } (P, \text{mk}); \end{aligned} \tag{1}$$

$$\begin{aligned} \text{Rep}(R', P) : \quad & c' = R' \oplus s, \quad \hat{r} = \mathbf{C}.\text{Decode}(c'), \quad \hat{c} = \mathbf{C}.\text{Encode}(\hat{r}), \quad \hat{R} = \hat{c} \oplus s, \\ & \text{return } \text{mk} = \text{KDF}(\text{Ext}_{\text{seed}}(\hat{R}); \text{“root”}). \end{aligned} \tag{2}$$

Lemma 1 (Correctness). *If the Hamming distance $d_H(R, R') \leq t$, then $\text{Rep}(R', P)$ recovers $\hat{R} = R$ and hence the identical mk.*

Proof. $c' = R' \oplus s = c \oplus (R \oplus R')$ differs from the codeword c in $d_H(R, R') \leq t$ positions, so bounded-distance decoding returns $\hat{r} = r$, whence $\hat{c} = c$ and $\hat{R} = \hat{c} \oplus s = R$. Thus both sides apply Ext and KDF to the identical R . $\square$ $\square$

Table 2: Notation (extends the reference design’s symbol table).

Symbol	Meaning
GS, UAV _{<i>i</i>}	ground station; <i>i</i> -th UAV
TID _{<i>i</i>}	(rotatable) temporary identity of UAV _{<i>i</i>}
PUF _{<i>i</i>} , <i>R</i> , <i>R'</i>	PUF of device <i>i</i> ; enrolment / field response
FE = (Gen, Rep)	fuzzy extractor, Eqs. (1) and (2)
<i>P_i</i> = (<i>s_i</i> , seed _{<i>i</i>})	<i>public</i> helper data
mk _{<i>i</i>}	stable per-device master key (never stored on UAV)
mk _{GS}	GS-only master key for pairwise credentials
Cred _{<i>ij</i>}	per-pair peer credential
<i>K_{auth}ⁱ</i> , <i>K_{auth}^{ij}</i>	derived MAC keys
SK _{<i>i</i>} , SK _{<i>ij</i>}	session keys (Phase 2 / Phase 3), forward-secret
<i>N_x</i> , <i>T_x</i>	128-bit nonce; timestamp
<i>a</i> , <i>b</i> ; <i>g^a</i> , <i>g^{ab}</i>	ephemeral X25519 scalars; public shares; shared secret
<i>T</i>	session transcript (all preceding message fields)
MAC, AE, KDF	keyed MAC; AEAD; key-derivation function

Lemma 2 (Helper-data privacy — *corrected form of the previous Assumption 4*). *Let $\tilde{H}_\infty(R) = m$ be the conditional min-entropy of the enrolment response. The code-offset sketch s leaks at most $n - k$ bits:*

$$\tilde{H}_\infty(R \mid P) \geq m - (n - k). \quad (3)$$

Consequently, if Ext is a $(m - (n - k), \varepsilon)$ -strong extractor with $\varepsilon = 2^{-\Omega(\lambda)}$ and output length $\ell \leq m - (n - k) - 2\log(1/\varepsilon)$, then mk is within statistical distance ε of uniform given P .

Proof. $s = R \oplus c$ is a deterministic function of R (given the internal r) and takes values in a coset of $\mathbb{C}$; revealing the coset of an $[n, k]$ code fixes at most $n - k$ syndrome bits, so by the chain rule for average min-entropy $\tilde{H}_\infty(R \mid s) \geq \tilde{H}_\infty(R) - (n - k)$; seed is independent of R . Applying the strong-extractor property to the residual source yields the stated distance. $\square$ $\square$

Remark 1 (Design constraint — why the old numbers could not hold). Equation (3) is a *bounded* loss, not the independence claimed previously. A single 128/255-bit arbiter response with $n - k = 124$ cannot supply $\ell = 2\lambda$ residual bits. The protocol therefore enrolls L independent response blocks $R = (R^{(1)}, \dots, R^{(L)})$ and requires

$$\sum_{b=1}^L (m_b - (n - k)) \geq \ell + 2\log(1/\varepsilon) \quad (\text{e.g. } \ell = 2\lambda), \quad (4)$$

choosing L from the measured per-block min-entropy m_b . This is the honest replacement for the previous “negligible leakage” statement.

3 System and Threat Model

The system has one trusted GS with tamper-resistant storage and N UAVs, each with a PUF, a lightweight processor, and non-volatile memory (NVM). We adopt the **Dolev–Yao** network adversary augmented with physical capture and an explicit challenge-oracle capability, so that the attack that broke the previous design is *inside* the model:

- **Network** ($\mathcal{A}_{\text{net}}$). Reads, injects, modifies, reorders, replays, delays, and drops any message.

- **Active challenger** ($\mathcal{A}_{\text{chal}}$). May attempt to act as GS toward an honest UAV and send *adversarially chosen* challenges/nonces (models the old chosen-challenge oracle).
- **Capture** ($\mathcal{A}_{\text{cap}}$). May capture a chosen device k and read its NVM contents $\{\text{TID}_k, P_k, \{\text{Cred}_{kj}\}_j\}$ together with any live session keys. By Assumption 2 it does *not* obtain PUF_k and hence cannot recover mk_k (which is never stored).
- **Reveal (for PFS)**. May, *after* a target session closes, learn long-term secrets $(\text{mk}_i, \text{Cred}_{ij})$ via a Reveal query.

The adversary is PPT and cannot invert h , forge MAC/AE, break the PUF (Assumption 1), or solve gap-CDH, except with negligible probability. Side channels are out of scope (constant-time primitives assumed), consistent with prior work.

4 Design Rationale: From Defects to Guarantees

- D1. Stable PUF-derived key, no stored secret (A.1, A.2, A.6).** Enrolment fixes a *stable* mk_i via FE. The UAV regenerates mk_i on demand from its PUF and *public* P_i ; nothing secret is in NVM. Every authenticator is now a MAC under a key derived from mk_i , which only the genuine device (PUF) and GS (database) can compute.
- D2. The raw response never leaves the device (A.2).** FE runs entirely on the UAV; the wire never carries R or any function of R under an attacker-controlled mask. There is thus no response to harvest and no masking to strip.
- D3. Abort-before-response (A.2).** The UAV verifies the GS’s MAC *before* performing any PUF-dependent action or emitting any message; a forged GS message is rejected silently.
- D4. Per-pair credentials under AEAD (A.3, A.7).** Peer trust uses per-pair Cred_{ij} delivered under $\text{AE.Enc}_{\text{SK}_i}$ —confidential and authenticated—replacing the plaintext swarm-wide credential. Domain-separated labels and per-message-type tags remove reflection/key-confusion.
- D5. Mandatory authenticated ephemeral DH (A.4).** Every session key mixes in a fresh g^{ab} whose public shares are bound into the MAC transcript; there is no non-DH fallback.
- D6. Correct entropy accounting (A.5).** Theorem 2 and Eq. (4) replace the false independence claim with a min-entropy bound and an explicit design inequality.

5 The Hardened Four-Phase Protocol

5.1 Phase 1 — Secure Enrolment

Performed once per device over a secure out-of-band channel.

Algorithm 1 Phase 1: Enrolment of UAV_i

- 1: GS selects challenge block $\mathbf{C}_i = (C_i^{(1)}, \dots, C_i^{(L)})$; evaluates $R \leftarrow \text{PUF}_i(\mathbf{C}_i)$ in situ
 - 2: $(P_i, \text{mk}_i) \leftarrow \text{FE.Gen}(R)$ $\triangleright L$ chosen per Eq. (4)
 - 3: GS stores $\langle \text{TID}_i, \mathbf{C}_i, P_i, \text{mk}_i \rangle$ in tamper-resistant DB
 - 4: UAV_i stores $\langle \text{TID}_i, \mathbf{C}_i, P_i \rangle$ only $\triangleright P_i$ public; **no secret in NVM**
-

The stored mk_i is the sole long-term secret and it lives only in the GS tamper-resistant DB; the UAV reconstructs it transiently.

5.2 Phase 2 — UAV $\leftrightarrow$ GS Mutual Authentication

A three-message authenticated key exchange. Let $K_{\text{auth}}^i = \text{KDF}(\text{mk}_i; \text{"p2-auth"})$. Ephemeral X25519 shares g^a (UAV) and g^b (GS) provide forward secrecy.

Algorithm 2 Phase 2: Mutual authentication and forward-secret keying

- 1: **UAV** $\rightarrow$ **GS** (M_1): draw N_1, a ; $\sigma_1 = \text{MAC}_{K_{\text{auth}}^i}(\text{"M1"} \parallel \text{TID}_i \parallel N_1 \parallel T_1 \parallel g^a)$; send $\langle \text{TID}_i, N_1, T_1, g^a, \sigma_1 \rangle$
 - 2: **GS**: reject if $|T_{\text{now}} - T_1| > \Delta T$ or N_1 seen; look up mk_i ; verify σ_1 ; else abort
 - 3: **GS** $\rightarrow$ **UAV** (M_2): draw N_2, b ; $\sigma_2 = \text{MAC}_{K_{\text{auth}}^i}(\text{"M2"} \parallel \text{TID}_i \parallel N_1 \parallel N_2 \parallel T_2 \parallel g^a \parallel g^b)$; send $\langle N_2, T_2, g^b, \sigma_2 \rangle$
 - 4: **UAV**: $\text{mk}_i \leftarrow \text{FE.Rep}(\text{PUF}_i(C_i), P_i)$; **verify** σ_2 *first*; if invalid, abort silently $\triangleright$ no response emitted $\Rightarrow$ no oracle
 - 5: **UAV** $\rightarrow$ **GS** (M_3): $\sigma_3 = \text{MAC}_{K_{\text{auth}}^i}(\text{"M3"} \parallel \mathcal{T})$; send $\langle \sigma_3 \rangle$ $\triangleright \mathcal{T} = \text{all } M_1, M_2 \text{ fields}$
 - 6: **Both**: $\text{SK}_i = \text{KDF}(\text{mk}_i \parallel g^{ab} \parallel \mathcal{T}; \text{"p2-sess"})$; GS rotates TID_i
-

Remark 2. No PUF response or masked response appears in any message; R is consumed locally by FE.Rep (Eq. (2)). GS already holds mk_i , so no challenge-response value is transmitted. mk_i is reusable, so there is no single-use challenge budget to exhaust (A.6); the optional block set C_i supports periodic key refresh, not per-session consumption.

5.3 Phase 3 — UAV $\leftrightarrow$ UAV Peer Authentication

GS mints *per-pair* credentials and distributes them under AEAD.

Algorithm 3 Phase 3: Per-pair credential issuance and peer handshake

- 1: **Issuance.** For peers $i < j$: $\text{Cred}_{ij} = \text{KDF}(\text{mk}_{\text{GS}}; \text{"pair-cred"} \parallel i \parallel j)$. **GS** $\rightarrow$ **UAV_i**: $\text{AE.Enc}_{\text{SK}_i}(\eta; i \parallel j; \text{Cred}_{ij})$; symmetrically to **UAV_j**
 - 2: **UAV_i**: $\text{Cred}_{ij} \leftarrow \text{AE.Dec}_{\text{SK}_i}(\dots)$; abort on $\perp$ $\triangleright$ confidential + authenticated
 - 3: Let $K_{\text{auth}}^{ij} = \text{KDF}(\text{Cred}_{ij}; \text{"peer-auth"})$
 - 4: **UAV_i** $\rightarrow$ **UAV_j** (P_1): draw n_i, a' ; $\tau_1 = \text{MAC}_{K_{\text{auth}}^{ij}}(\text{"P1"} \parallel i \parallel j \parallel n_i \parallel T \parallel g^{a'})$
 - 5: **UAV_j** $\rightarrow$ **UAV_i** (P_2): verify τ_1 ; draw n_j, b' ; $\tau_2 = \text{MAC}_{K_{\text{auth}}^{ij}}(\text{"P2"} \parallel i \parallel j \parallel n_i \parallel n_j \parallel g^{a'} \parallel g^{b'})$
 - 6: **UAV_i** $\rightarrow$ **UAV_j** (P_3): verify τ_2 ; $\tau_3 = \text{MAC}_{K_{\text{auth}}^{ij}}(\text{"P3"} \parallel \mathcal{T})$
 - 7: **Both**: $\text{SK}_{ij} = \text{KDF}(\text{Cred}_{ij} \parallel g^{a'b'} \parallel \mathcal{T}; \text{"peer-sess"})$
-

Remark 3. Each message type carries a distinct tag ("P1", "P2", "P3") and a freshness element (n_i, n_j, T) , removing the reflection/oracle-confusion of A.7; SK_{ij} uses the label "peer-sess", independent of the authenticator key K_{auth}^{ij} (label "peer-auth"), so key and authenticator can never collide.

5.4 Phase 4 — Session Keys and Mandatory Forward Secrecy

Phase 4 is the keying already embedded in Algorithms 2 and 3: authenticated ephemeral X25519 is *mandatory*. Both session keys have the form

$$\text{SK} = \text{KDF}\left(\underbrace{k_{\text{lt}}}_{\text{mk}_i \text{ or Cred}_{ij}} \parallel g^{xy} \parallel \mathcal{T}; \ell\right), \quad (5)$$

with the ephemeral public shares g^x, g^y authenticated inside the MAC transcript. There is no non-DH derivation path; if the ephemeral exchange is absent the session fails closed.

6 Security Theorems and Game-Based Proofs

Throughout, q bounds the number of sessions/oracle queries and reductions are tight up to the stated additive terms.

Theorem 3 (Phase-2 mutual authentication). *Under Assumption 1, EUF-CMA security of MAC, and PRF security of KDF, Algorithm 2 achieves mutual entity authentication with injective agreement on $\mathcal{T}$. For every PPT $\mathcal{A}$,*

$$\text{Adv}^{\text{p2-auth}}(\mathcal{A}) \leq 2 \text{Adv}_{\text{MAC}}^{\text{euf}}(\mathcal{A}') + \text{Adv}_{\text{KDF}}^{\text{prf}}(\mathcal{A}'') + q^2/2^{128} + \text{negl}(\lambda).$$

Proof. $K_{\text{auth}}^i = \text{KDF}(\text{mk}_i; \text{"p2-auth"})$. **Game** G_0 is the real authentication game. G_1 replaces K_{auth}^i by a uniform key; by PRF security of KDF and, beneath it, near-uniformity of mk_i (Theorem 2, so mk_i is unknown to any $\mathcal{A}$ lacking either the PUF or the DB, by Assumption 1), $|\Pr[G_1] - \Pr[G_0]| \leq \text{Adv}_{\text{KDF}}^{\text{prf}} + \text{negl}$. (*GS authenticates UAV.*) A UAV is accepted only if σ_1 verifies under K_{auth}^i ; producing a fresh valid σ_1 without the key is an EUF-CMA forgery. (*UAV authenticates GS.*) Symmetrically for σ_2 ; crucially every input of σ_2 is either public *or* authenticated, but the *key* is secret—unlike the previous β_1 , which was unkeyed. A nonce collision (N_1 or N_2) that would permit transcript reuse occurs with probability $\leq q^2/2^{128}$. Absent forgery and collision, accepting parties share the same $\mathcal{T}$ (injective agreement). Summing the two forgery terms gives the bound. $\square$ $\square$

Corollary 4 (No chosen-challenge PUF oracle). *An active $\mathcal{A}_{\text{chal}}$ impersonating GS cannot obtain any PUF response value. Hence the modelling-attack vector of defect A.2 is closed without any physical assumption beyond Assumption 1.*

Proof. By line 4 of Algorithm 2 the UAV emits M_3 only after σ_2 verifies. By Theorem 3, forging σ_2 succeeds with probability $\leq \text{Adv}_{\text{MAC}}^{\text{euf}} + \text{negl}$. When verification fails the UAV emits nothing, and even when it succeeds the wire carries only σ_3 , a MAC over public transcript fields—never R or a function of R under an attacker-chosen mask. Thus no CRP is revealed for any (chosen or otherwise) challenge. $\square$ $\square$

Theorem 5 (Phase-3 peer mutual authentication). *Under EUF-CMA of MAC and INT-CTXT of AE, Algorithm 3 achieves peer mutual authentication with injective agreement, without GS participation at handshake time, and with no per-pair secret ever exposed in transit:*

$$\text{Adv}^{\text{p3-auth}}(\mathcal{A}) \leq 2 \text{Adv}_{\text{MAC}}^{\text{euf}}(\mathcal{A}') + 2 \text{Adv}_{\text{AE}}^{\text{int}}(\mathcal{A}'') + q^2/2^{128} + \text{negl}.$$

Proof. Issuance. Cred_{ij} is delivered as $\text{AE.Enc}_{\text{SK}_i}$; by INT-CTXT the adversary cannot produce a ciphertext the UAV accepts as a different credential, and by IND-CCA it learns nothing about Cred_{ij} (used below in Theorem 8). SK_i is a fresh, forward-secret key (Theorems 3 and 9) held only by UAV_i and GS. Hence a PPT adversary’s view is independent of Cred_{ij} except with $\leq \text{Adv}_{\text{AE}}^{\text{int}}$ per endpoint. *Handshake.* Given secret Cred_{ij} , the tokens τ_1, τ_2, τ_3 are MACs under K_{auth}^{ij} ; each carries a distinct type tag and binds both identities and both nonces, so a fresh acceptance forces a matching sender computation—otherwise an EUF-CMA forgery. A dishonest *third* party, even one holding some $\text{Cred}_{k\ell}$, has no information about Cred_{ij} (distinct KDF inputs), so it cannot fill in i ’s identity, unlike the previous swarm-wide Cred. Nonce collisions contribute $\leq q^2/2^{128}$. $\square$ $\square$

Theorem 6 (Replay and MITM resistance). *Algorithms 2 and 3 resist replay and active man-in-the-middle attacks.*

Proof. Every accepted message is a MAC over a transcript that includes a fresh 128-bit nonce, a timestamp checked within ΔT , a per-message type tag, and (from M_2/P_2 onward) the peer’s nonce. A replay reuses a stale nonce/timestamp and is rejected by the freshness cache or window; a cross-session or cross-type substitution changes a MAC input and, by Theorems 3 and 5, cannot be re-authenticated without the key. An active MITM altering any field invalidates the covering MAC; injective agreement on $\mathcal{T}$ (Theorems 3 and 5) then guarantees both endpoints share the identical view. The distinct type tags additionally prevent reflecting a P_1 token as a P_3 token (closing A.7). $\square$ $\square$

Theorem 7 (Physical-capture resistance). *Capture of UAV_k (reading its NVM) does not let $\mathcal{A}_{\text{cap}}$ (i) impersonate any UAV_m ($m \neq k$) to GS in a fresh Phase 2, nor (ii) impersonate any peer pair (m, ℓ) with $k \notin \{m, \ell\}$ in Phase 3. The peer-authentication blast radius of a captured node is exactly its $N - 1$ incident links.*

Proof. The captured NVM contains $\{\text{TID}_k, P_k, \{\text{Cred}_{kj}\}_j, \text{live SK}\}$. (i) A fresh Phase 2 as UAV_m requires $K_{\text{auth}}^m = \text{KDF}(\text{mk}_m; \cdot)$; mk_m is never stored (Alg. 1) and, by Assumption 2, is not recoverable from k ’s silicon, while Assumption 1 makes it unpredictable. Hence forging Phase 2 for $m \neq k$ reduces to EUF-CMA/PUF, negligible. (ii) Phase 3 for (m, ℓ) requires $\text{Cred}_{m\ell} = \text{KDF}(\text{mk}_{\text{GS}}; \cdot)$; the captured set $\{\text{Cred}_{kj}\}$ is independent of $\text{Cred}_{m\ell}$ for $k \notin \{m, \ell\}$ (distinct KDF inputs, mk_{GS} never leaves GS), so acceptance reduces to EUF-CMA. Only pairs incident to k share a captured credential, giving the stated $N - 1$ blast radius—a $\binom{N}{2}^{-1}(N - 1)$ fraction versus the previous whole-swarm compromise. $\square$ $\square$

Theorem 8 (Session-key secrecy). *For an adversary that does not corrupt an endpoint of the target session, SK_i (resp. SK_{ij}) is indistinguishable from uniform: $\text{Adv}^{\text{key-ind}}(\mathcal{A}) \leq \text{Adv}_{\text{KDF}}^{\text{prf}} + \text{Adv}^{\text{gap-cdh}} + \text{negl}$.*

Proof. By Eq. (5) the key is $\text{KDF}(k_{\text{lt}} \parallel g^{xy} \parallel \mathcal{T})$. Two independent secrets protect it: the long-term key k_{lt} (mk_i by Theorem 2+Assumption 1, or Cred_{ij} by IND-CCA of the AEAD delivery, Theorem 5) and the DH secret g^{xy} . Model KDF as a PRF: replacing it by a random function costs $\text{Adv}_{\text{KDF}}^{\text{prf}}$; the input g^{xy} is unpredictable under gap-CDH given only g^x, g^y (authenticated, so not adversarially substituted, by Theorems 3 and 5). Hence the output is uniform up to the stated terms. $\square$ $\square$

Theorem 9 (Perfect forward secrecy). *If the ephemeral scalars are erased after use, then revealing the long-term secrets (mk_i , Cred_{ij} , and even mk_{GS}) after a target session closes does not compromise that session’s key: $\text{Adv}^{\text{pfs}}(\mathcal{A}) \leq \text{Adv}^{\text{gap-cdh}} + \text{Adv}_{\text{KDF}}^{\text{prf}} + \text{negl}$.*

Proof. Post-session Reveal gives $\mathcal{A}$ the value k_{lt} but not the erased x, y . The key Eq. (5) still depends on g^{xy} , which $\mathcal{A}$ must compute from the transcript shares g^x, g^y —a gap-CDH instance, since the shares were authenticated (no MITM substitution by Theorems 3 and 5) and the scalars are gone. Reducing KDF to a PRF on the now-unknown input g^{xy} yields indistinguishability up to the stated terms. Because the exchange is mandatory and fail-closed (Section 5.4), there is no non-DH session key to attack—removing the silent-fallback defect of A.4. $\square$ $\square$

7 Symbolic Model and Mechanised Verification

The game-based proofs are complemented by a symbolic model in the **Tamarin** multiset-rewriting calculus (chosen over ProVerif because the protocol uses stateful credential issuance and the analysis benefits from native reasoning about freshness and reveal rules). We summarise the model; the idealisations are stated explicitly for honesty.

Model. $h, \text{MAC}, \text{AE}, \text{KDF}$ are free function symbols with the usual equational theory

$$\text{AE.Dec}_k(\eta; ad; \text{AE.Enc}_k(\eta; ad; m)) = m.$$

Each PUF is a private per-device function $\text{puf}(\sim \text{seed}_i, c)$; helper data and all wire terms are public. GS's database and issued credentials are linear facts. Fresh values ($\sim N, \sim a$) model nonces and ephemeral scalars; g^{ab} is modelled with the built-in Diffie–Hellman theory.

Adversary and reveal rules. The Dolev–Yao adversary controls the network. Additional rules **Reveal_NVM**(k) (emits $\text{TID}_k, P_k, \{\text{Cred}_{kj}\}$ but *not* puf_k or mk_k) and **Reveal_LT** (emits mk_i or Cred_{ij} , timestamped after session close) encode capture (Theorem 7) and PFS (Theorem 9).

Lemmas (to be discharged by tamarin-prover --prove).

```
lemma p2_injective_agreement:    // Theorem 1
  "All U GS t #i. Commit(U,GS,<'p2',t>@i
    ==> (Ex #j. Running(GS,U,<'p2',t>@j & j<i)
      & not (Ex U2 GS2 #i2. Commit(U2,GS2,<'p2',t>@i2 & not #i2=#i))"

lemma p3_injective_agreement:    // Theorem 2
  "All i j t #x. Commit(i,j,<'p3',t>@x
    ==> (Ex #y. Running(j,i,<'p3',t>@y & y<x)"

lemma no_replay:                  // Theorem 3
  "All t #a #b. Accept(t)@a & Accept(t)@b ==> #a=#b"

lemma capture_isolation:         // Theorem 4
  "All m l #x. PeerKey(m,l)@x & (Ex k #r. RevealNVM(k)@r & not k=m & not k=l)
    ==> not (Ex #e. K(SKpair(m,l))@e)"

lemma key_secretcy:              // Theorem 5
  "All k #x. SessionKey(k)@x & not (Ex #r. RevealEndpoint()@r)
    ==> not (Ex #e. K(k)@e)"
```

```

lemma forward_secretary:           // Theorem 6
  "All k #x. SessionKey(k)@x
    & (All #r. RevealLT()@r ==> x<r)    // reveal only after close
    ==> not (Ex #e. K(k)@e)"

```

Idealisations (disclosed). (i) The noisy PUF is modelled as a noiseless private function—the fuzzy extractor’s error tolerance (Theorem 1) is a computational correctness property outside the symbolic model. (ii) The masked-value constructions are replaced by symmetric encryption `senc`, and XOR is not modelled as an equational theory, so the symbolic layer over-abstracts confidentiality; the computational layer (Theorem 8) covers those details. A deliberate re-introduction of the old plaintext-credential rule must make `key_secretary` fail—a regression test for the model itself.

8 Comparison with the Previous Specification

Table 3: Security properties: previous vs. hardened theory.

Property / defect	Previous	This work
GS→UAV authentication (A.1)	unsound	keyed MAC, Thm. 3
Chosen-challenge PUF oracle (A.2)	present	closed, Cor. 4
Peer credential (A.3)	plaintext, swarm-wide	per-pair AEAD, Thm. 5
Forward secrecy (A.4)	none / silent no-DH	mandatory, Thm. 9
Helper-data assumption (A.5)	false “independence”	$\tilde{H}_\infty$ bound, Lem. 2
CRP exhaustion / DoS (A.6)	single-use, unauth. M_1	reusable mk_i , auth. M_1
Domain separation / freshness (A.7)	absent	labels + tags + nonces
Capture blast radius	whole swarm	$N-1$ links, Thm. 7
Proof rigour	informal sketches	games + symbolic model

9 Conclusion

The hardened theory roots all authentication in a stable, PUF-derived master key that is never stored, keeps the raw PUF response off the wire, replaces the swarm-wide plaintext credential with per-pair AEAD-protected secrets, and makes an authenticated ephemeral Diffie–Hellman exchange a mandatory, fail-closed component of every session key. The helper-data assumption is restated as a correct min-entropy bound with an explicit design inequality. Six theorems—proved by reduction to standard assumptions and mirrored by a mechanisable symbolic model—replace the previous informal and, in four cases, unsound arguments. Every defect catalogued in Table 1 is resolved (Table 3).